Case Study 1: E-Commerce Application — Broken Access Control and Authentication Failures

Scenario

An online fashion store provides customers with accounts to view orders, manage addresses, and download invoices. Each order has a URL such as:

```
/orders/view?id=10452
```

During security testing, an authenticated customer changes the ID to another value:

```
/orders/view?id=10453
```

The application displays another customer's order details without checking whether the logged-in user owns that order.

The application also allows users to remain logged in for several days without re-authentication, and password-reset links remain valid for a long period.

Questions

1. Which OWASP Top 10 category is most directly demonstrated by the ability to access another customer's order?
2. What authorization check should the application perform before displaying an order?
3. Why is relying only on the order ID insufficient for access control?
4. Which security controls could reduce the risk associated with long-lived sessions?
5. What additional security mechanisms should be implemented for password recovery?
6. Explain how an attacker could exploit this vulnerability ethically in a controlled test environment.
7. Identify two logging mechanisms that could help detect unauthorized access attempts.

Case Study 2: Banking Web Application — Injection and Security Misconfiguration

Scenario

A banking application contains a customer-search feature used by employees. The application constructs database queries using data entered into a search box without properly separating user input from SQL commands.

Security testing reveals that specially crafted input changes the behavior of the database query.

The application's production server also exposes detailed error messages containing database information, software versions, and internal file paths.

Questions

1. Which OWASP Top 10 category is associated with improperly handled database input?
2. Why can directly incorporating user input into database queries be dangerous?
3. What programming technique should be used to prevent SQL injection?
4. Which OWASP category is relevant to unnecessarily detailed production error messages?
5. Why should stack traces and database information generally not be displayed to users?
6. Identify two security-hardening measures that could reduce the application's attack surface.
7. How could developers safely test the application for injection vulnerabilities without targeting a real banking system?

Case Study 3: University Portal — XSS, Cryptographic Failures and Vulnerable Components

Scenario

A university web portal allows students to post comments on course pages. The application stores comments and later displays them to other users without adequately encoding HTML content.

A security tester discovers that specially crafted content can cause browser-side script execution when another user views the comment.

The portal also stores sensitive student information using weak or inappropriate protection. Furthermore, an outdated third-party JavaScript library with a publicly documented vulnerability is being used.

Questions

1. Which OWASP Top 10 category is associated with the stored browser-side script vulnerability?
2. What is the difference between stored XSS and reflected XSS?
3. What role does output encoding play in preventing XSS?
4. Which OWASP category is relevant to inadequate protection of sensitive data?
5. Why should sensitive information be protected both during transmission and storage?
6. Which OWASP category covers the use of outdated or vulnerable third-party components?
7. What process should the university follow to identify and remediate vulnerable dependencies?

Multiple-Select Questions (MSQs)

Instruction: Select **all correct answers**. More than one option may be correct.

1. Which of the following are associated with OWASP Top 10 application security risks?

A. Broken Access Control
B. Injection
C. Security Misconfiguration
D. Increased CPU clock speed
E. Cryptographic Failures

2. Which situations may indicate Broken Access Control?

A. A user accesses another user's invoice
B. A normal user accesses an administrator-only function
C. A user modifies an object identifier and obtains unauthorized data
D. A password contains fewer than eight characters
E. A user bypasses authorization checks through a manipulated request

3. Which measures can help prevent Broken Access Control?

A. Server-side authorization checks
B. Deny-by-default access policies
C. Enforcing permissions for every protected resource
D. Relying only on hidden UI buttons
E. Proper role-based access control

4. Which are examples of authentication-related weaknesses?

A. Weak password-reset mechanisms
B. Improper session management
C. Credential stuffing susceptibility
D. Strong multi-factor authentication
E. Weak or predictable authentication credentials

5. Which practices strengthen authentication security?

A. Multi-factor authentication
B. Secure password storage
C. Rate limiting authentication attempts
D. Reusing the same password for every account
E. Secure session management

6. Which of the following may represent Injection vulnerabilities?

A. SQL injection
B. Command injection
C. LDAP injection
D. Properly parameterized database queries
E. Some forms of expression-language injection

7. Which techniques can help prevent SQL injection?

A. Parameterized queries
B. Prepared statements
C. Appropriate input validation
D. Concatenating user input directly into SQL statements
E. Least-privilege database accounts

8. Which are examples of Security Misconfiguration?

A. Unnecessary services being enabled
B. Default administrative credentials remaining unchanged
C. Detailed stack traces exposed to users

D. Properly hardened server configurations
E. Unnecessary directory listing being enabled

9. Which practices can reduce Security Misconfiguration?

A. Removing unnecessary services
B. Changing default credentials
C. Applying secure configuration baselines
D. Exposing debugging information in production
E. Regular configuration reviews

10. Which situations may fall under Cryptographic Failures?

A. Sensitive information transmitted without adequate encryption
B. Weak cryptographic algorithms used for sensitive information
C. Sensitive data stored without appropriate protection
D. Correct use of modern cryptographic mechanisms
E. Poor key management

11. Which practices are relevant to protecting sensitive information?

A. Using appropriate encryption during transmission
B. Secure key management
C. Minimizing unnecessary collection of sensitive information
D. Storing passwords in plaintext
E. Using appropriate cryptographic algorithms

12. Which statements about XSS are correct?

A. XSS can cause script execution in a victim's browser
B. Stored XSS can persist on the server-side application or database
C. Output encoding can help prevent XSS
D. XSS is exclusively a database vulnerability
E. Input validation can contribute to XSS defense

13. Which are examples of XSS types?

A. Stored XSS
B. Reflected XSS
C. DOM-based XSS

D. Network-layer XSS
E. Browser-side script injection

14. Which practices can help mitigate XSS?

A. Context-appropriate output encoding
B. Content Security Policy
C. Safe handling of untrusted HTML
D. Blindly trusting all user-supplied HTML
E. Appropriate input validation

15. Which situations may indicate a vulnerable or outdated component?

A. An outdated JavaScript library with a known vulnerability
B. An unsupported framework version
C. A dependency with an unpatched critical vulnerability
D. A regularly updated dependency with no known vulnerabilities
E. An obsolete server component no longer receiving security updates

16. Which practices help manage vulnerable components?

A. Maintaining a software inventory
B. Monitoring security advisories
C. Updating vulnerable dependencies
D. Ignoring third-party libraries
E. Removing unnecessary dependencies

17. Which are examples of security logging and monitoring practices?

A. Recording authentication failures
B. Monitoring suspicious access attempts
C. Recording important security events
D. Disabling all logs to improve performance
E. Establishing mechanisms for alerting on suspicious activity

18. Which events could be useful for detecting application attacks?

A. Repeated failed login attempts
B. Unusual administrative actions
C. Repeated attempts to access unauthorized resources
D. Successful page loading under normal conditions only
E. Suspicious input patterns detected by security controls

19. Which practices contribute to secure software development?

A. Threat modeling
B. Secure coding guidelines
C. Security testing during development
D. Ignoring security until deployment
E. Dependency security management

20. Which activities can be included in application security testing?

A. Static application security testing
B. Dynamic application security testing
C. Dependency vulnerability scanning
D. Authorization testing
E. Disabling security controls before testing and leaving them disabled

21. Which statements about input validation are correct?

A. It can restrict input to expected formats
B. It can reduce certain classes of malicious input
C. It should be treated as the only defense against SQL injection
D. It can help reduce application attack surface
E. It should be combined with other security controls

22. Which security principles are useful when implementing OWASP-aligned applications?

A. Least privilege
B. Defense in depth
C. Secure-by-design development
D. Fail securely
E. Trust all client-side input

23. Which are examples of authorization checks?

A. Verifying whether a user owns a requested resource
B. Checking whether a user's role permits an operation
C. Confirming whether an administrator-only function can be accessed by the requesting user
D. Checking only whether the user has a valid browser
E. Enforcing permissions on the server

24. Which activities are appropriate for an ethical web application security assessment?

A. Testing an application with explicit authorization
B. Using a controlled test environment
C. Documenting discovered vulnerabilities
D. Testing unrelated third-party websites without permission
E. Recommending remediation measures

25. Which statements correctly describe the purpose of the OWASP Top 10?

A. It highlights important categories of web application security risks
B. It can help developers prioritize application security awareness
C. It can support security testing and secure-development discussions
D. It guarantees that an application is completely secure if all categories are addressed
E. It can be used as an awareness and risk-management reference